

Chapter 5 — Short Notes

Incident Response, Forensics & Cyber Laws

Information Security | B.Tech Computer Engineering | K. J. Somaiya College of Engineering

ESE-Oriented | Based on 2023, 2024 & 2025 Question Papers

1. Incident Response Life Cycle

The Incident Response Life Cycle is a structured 6-phase process for managing cybersecurity incidents from preparation through recovery and learning.

📌 Asked in: 2023 (laws & ethics Q), 2024 Q5 – short notes, 2025 Q5

Phase 1 – Preparation

The planning stage BEFORE any incident occurs. Organizations build their defense and readiness.

- **Policy** – Create incident response policies and procedures
- **Team** – Train staff and form an Incident Response Team (IRT)
- **Tools** – Install security tools: firewalls, IDS/IPS, antivirus
- **Drills** – Conduct risk assessments and simulation drills

🎯 **Goal:** Be ready to act quickly and effectively when an attack happens.

Phase 2 – Detection & Analysis

Identifying whether an incident has occurred and understanding its scope.

- **Monitor** – Monitor logs, alerts, and unusual system activities
- **SIEM** – Use SIEM tools (Security Information & Event Management) to detect threats
- **Analyze** – Analyze the type, source, and severity of the incident
- **Confirm** – Confirm if it is a real attack or a false alarm

🎯 **Goal:** Detect incidents early and accurately before damage spreads.

Phase 3 – Containment

Limit the damage and prevent the spread of the attack.

- **Isolate** – Disconnect affected systems from the network
- **Disable** – Disable compromised accounts immediately
- **Fix** – Apply temporary patches and blocks

Two types of containment:

- **Short-term** – Immediate action (e.g., pulling a server's network cable)
- **Long-term** – Temporary solutions until a full fix is applied (e.g., firewall rule)

🎯 **Goal:** Stop the attack from spreading and getting worse.

Phase 4 – Eradication

Remove the root cause of the incident completely.

- **Malware** – Delete all malware or malicious files from systems
- **Access** – Remove unauthorized access points and backdoors
- **Patch** – Fix the vulnerability — patch software, update configurations

🎯 **Goal:** Completely eliminate the threat from the environment.

Phase 5 – Recovery

Restore systems to normal, safe operation.

- **Restore** – Restore data from clean, verified backups
- **Monitor** – Monitor systems closely for any signs of recurrence
- **Reconnect** – Gradually reconnect systems to the network

🎯 **Goal:** Safely resume business operations without risk of reinfection.

Phase 6 – Lessons Learned

Analyze the incident and improve processes for the future.

- **Document** – Document what happened and how it was handled step by step
- **Gaps** – Identify gaps in security or incident response procedures
- **Update** – Update policies, tools, and staff training based on findings

🎯 **Goal:** Prevent similar incidents from occurring in the future.

📌 **EXAM TIP:** The 6 phases in order: Preparation → Detection & Analysis → Containment → Eradication → Recovery → Lessons Learned. Easy mnemonic: PD-CERL

2. Computer Emergency Response Team (CERT)

A CERT is a specialized group of cybersecurity experts responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization or a country.

📌 Asked in: 2023 (laws & ethics Q), 2025 Q5 – short notes

8 Key Roles & Responsibilities of CERT

#	Role	Description
01	Incident Detection & Analysis	Monitors systems/networks for security breaches; identifies malicious activities in real-time
02	Incident Response	Takes swift, coordinated actions to contain and mitigate cyberattacks (e.g., data breaches, malware)
03	Threat Intelligence	Gathers, analyzes, and shares information about current & emerging cyber threats
04	Vulnerability Management	Identifies and fixes weaknesses in software, hardware, and network infrastructure
05	Coordination & Collaboration	Works with internal teams, law enforcement, and regulatory bodies during incidents
06	Forensic Analysis	Conducts post-incident investigations to find root cause, damage extent, and remediation steps
07	Training & Awareness	Educates staff about cybersecurity best practices and promotes a security-aware culture
08	Policy Development	Develops and implements cybersecurity policies, procedures, and guidelines

📌 **EXAM TIP:** CERT roles follow the lifecycle: Detect → Respond → Analyze → Train → Policy. Remember: CERT is reactive AND proactive.

3. Key Digital Forensics Techniques

Digital forensics is the science of collecting, preserving, analyzing, and presenting digital evidence from electronic devices to investigate cybercrimes.

📌 Asked in: 2023 Q4 (forensics/post-incident), 2024 Q5 (digital signatures), 2025 Q5

7 Core Forensics Techniques

- **Disk Imaging / Acquisition** – Creates a bit-for-bit copy (clone) of storage media (hard drives, USBs). Uses tools like FTK Imager or dd. The original is NEVER analyzed directly.
- **File Carving** – Recovers deleted files or fragments from unallocated disk space WITHOUT relying on file system metadata. Useful when files are partially overwritten.
- **Memory Forensics** – Analyzes volatile RAM to extract running processes, active network connections, encryption keys, and passwords. Uses Volatility Framework.
- **Live Data Acquisition** – Captures data from a RUNNING system before shutdown to prevent loss of volatile evidence (RAM contents, open files, network connections).
- **Network Forensics** – Monitors and analyzes network traffic to track malicious activity, unauthorized connections, and data exfiltration. Primary tool: Wireshark.
- **Email & Keyword Analysis** – Searches emails and metadata to trace communications, recover deleted messages, and identify suspicious keywords or senders.
- **Reverse Steganography** – Detects hidden data concealed within images, audio files, or documents that appear innocent on the surface.

Top Forensics Tools (Short Notes Format)

Tool	Type	Primary Use
Autopsy	Open-source GUI	Analyze disk images, generate forensic reports
Magnet AXIOM	Commercial	Evidence from computers, mobiles, and cloud services
EnCase	Commercial	Comprehensive data collection and analysis
Volatility	Open-source	Advanced RAM/memory forensics
FTK Imager	Open-source	Create forensic disk images quickly and securely
Bulk Extractor	Open-source	Scan disk images to extract URLs, emails, credit cards
Wireshark	Open-source	Capture and analyze live network traffic

4. Evidence Collection in Digital Forensics

Digital evidence is electronic data collected and analyzed to investigate cybercrimes and legal cases. The process converts raw media into court-admissible evidence.

4-Step Evidence Collection Process

Media → Data → Information → Evidence

Step 1: Data Collection

- Identify all potential sources of digital evidence
- Collect from computers, mobiles, servers, and storage media
- Ensure original data is NOT modified during collection (use write-blockers)
- Use forensic tools to create bit-for-bit copies (disk images)

Step 2: Examination

- Carefully inspect the collected data
- Filter information relevant to the investigation
- Detect hidden, deleted, or encrypted files
- Organize data for systematic analysis

Step 3: Analysis

- Apply forensic techniques to interpret the evidence
- Identify patterns, relationships, and suspicious activities
- Reconstruct the timeline of events using collected data
- Extract useful information that supports the investigation

Step 4: Reporting

- Document all findings clearly, accurately, and completely
- Present evidence in a structured, professional format
- Include details of all tools and methods used
- Prepare the final report for legal authorities or organizations

5. Chain of Custody

The chain of custody is the chronological, documented record of evidence handling — from the moment it is seized until it is presented in court. It proves that evidence was not tampered with.

📌 Asked in: 2023 Q4 (evidence integrity), 2025 Q4 (incident investigation)

Why It Matters

A broken chain of custody renders evidence UNRELIABLE and INADMISSIBLE in court, potentially causing a case to be dismissed entirely.

4 Key Components

- **Documentation** – Step-by-step log of every person who handled the evidence, with dates and times of each transfer
- **Unique Identifier** – Each piece of evidence (hard drive, USB, cloud log) is assigned a unique ID for tracking
- **Hashing** – Cryptographic algorithms (MD5, SHA-256) create a 'digital fingerprint' of the file — even a 1-bit change is detectable
- **Storage & Security** – Physical and digital safeguards prevent unauthorized access or tampering (e.g., evidence lockers, encrypted storage)

5 Steps in the Chain of Custody Process

1. Collection — Evidence collected; device, location, and collector recorded
2. Preservation — Evidence protected from alteration (Faraday bags for phones, write-blockers for drives)
3. Documentation — Chain of Custody Form must travel with the evidence at all times
4. Analysis — Always performed on a COPY, never the original evidence
5. Presentation — Evidence presented in court with documentation proving it is unchanged

📌 **EXAM TIP:** Key phrase: 'Analysis is on a COPY, never the original.' Hashing is the technical mechanism that proves integrity.

6. Information Technology Act, 2000 (IT Act)

India's primary cyber law providing a legal framework for electronic transactions, digital governance, and the prevention of cybercrimes.

📌 Asked in: 2023 Q5 (laws & ethics), 2024 Q5 (diff. laws/ethics), 2025 Q5 – Indian IT Act 2000

5 Key Features of the IT Act

- **Digital Signatures** – Legal recognition for electronic signatures in digital transactions; ensures authenticity and integrity of online contracts
- **Cybercrime Regulation** – Defines and penalizes offenses: hacking, identity theft, cyber terrorism, cyber stalking; provides legal remedies for victims
- **Cyber Cafes** – Defines cyber cafes as public internet venues; requires user identity records and security compliance
- **Overriding Provisions** – IT Act takes precedence over conflicting laws in cyber matters; works in harmony with Copyright Act, 1957
- **Regulation of Digital Media** – Rules for social media and digital content platforms; focuses on user safety, grievance redressal, and data privacy

Important Sections & Penalties

Section	Offense	Penalty
Sec. 43	Unauthorized access or damage to computer systems	Compensation for damages to system owner
Sec. 66	Hacking a computer system	Up to 3 years prison OR ₹5 lakh fine OR both
Sec. 66B,C,D	Fraud and identity theft	Up to 3 years prison OR ₹1 lakh fine OR both
Sec. 66E	Violation of privacy (transmitting private images)	Up to 3 years prison OR ₹2 lakh fine OR both
Sec. 66F	Cyber terrorism (threatening India's sovereignty/security)	LIFE IMPRISONMENT
Sec. 67	Publication of obscene content online	Up to 5 years prison OR ₹10 lakh fine OR both

📌 **EXAM TIP:** Section 66F (cyber terrorism) = Life imprisonment. Section 67 (obscene content) = 5 years. These are the extreme penalties — examiners love to test them!

7. Digital Personal Data Protection (DPDP) Act, 2023

India's comprehensive data privacy law enacted in August 2023, further strengthened by DPDP Rules 2025. It creates a framework to protect citizens' digital personal data.

📌 Asked in: 2025 Q5 (Indian IT Act / data protection)

Scope of the DPDP Act

- Applies to digital personal data processed within India
- Also applies to entities outside India that offer goods/services to Indian residents
- Covers data processed online OR offline if later digitized

6 Key Highlights

- **Data Principal Rights** – Individuals (called 'Data Principals') have the right to: Access, Correct, Erase, and Withdraw consent for their personal data
- **Data Fiduciary Obligations** – Organizations handling data ('Data Fiduciaries') must: Provide notice, obtain clear consent, ensure accuracy, and delete data once the purpose is met
- **Child Protection** – Processing data of individuals under 18 requires parental consent; targeting children with harmful advertising is strictly prohibited
- **Significant Data Fiduciaries (SDF)** – Government can designate high-risk entities as SDFs — they must appoint a Data Protection Officer, conduct impact assessments, and independent audits
- **Penalties** – Data breaches can lead to fines up to ₹250 crore for failure to prevent data breaches
- **Data Protection Board of India** – A regulatory body established to: monitor compliance, hear user grievances, and impose penalties

📌 **EXAM TIP:** DPDP 2023 is India's answer to GDPR. Data Principal = individual user; Data Fiduciary = the company/organization handling data.

8. International Cybersecurity Laws — GDPR & HIPAA

Two of the most important international cybersecurity regulations with extraterritorial reach. Both mandate strict data protection and breach reporting requirements.

📌 Asked in: 2023 Q5, 2024 Q5 (difference between laws/ethics), 2025 Q5

GDPR — General Data Protection Regulation (EU)

- **Full Name** – General Data Protection Regulation
- **Origin** – European Union — effective May 2018
- **Scope** – Protects personal data of ALL EU/EEA residents
- **Application** – EXTRATERRITORIAL — applies to any organization worldwide that processes EU resident data
- **Data Protected** – All personal data: name, email, IP address, location, browsing history, biometrics, etc.
- **Consent** – Requires CLEAR, INFORMED, and EXPLICIT consent before collecting data
- **Breach Notification** – Must notify authorities within 72 hours of discovering a breach
- **Rights Granted** – Access, Correct, Delete (Right to be Forgotten), Restrict, Transfer data
- **Penalties** – Up to €20 Million OR 4% of global annual turnover — whichever is higher

HIPAA — Health Insurance Portability and Accountability Act (USA)

- **Full Name** – Health Insurance Portability and Accountability Act
- **Origin** – United States — enacted 1996
- **Scope** – Protects Protected Health Information (PHI) in the US healthcare sector
- **Application** – Covers healthcare providers, health plans, hospitals, and their business associates
- **Data Protected** – Only PHI: health conditions, treatments, billing, health history, test results
- **Consent** – Depends on the purpose: treatment, payment, or healthcare operations
- **Requirements** – Administrative safeguards, Physical safeguards, Technical safeguards + Breach Notification Rule
- **Penalties** – Tiered penalties: \$100 to \$1.5 million per violation category per year

GDPR vs. HIPAA — Key Differences

Aspect	GDPR (EU)	HIPAA (USA)
Data Protected	ALL personal data (email, IP, location...)	Only health information (PHI)
Jurisdiction	Worldwide — any org handling EU data	US healthcare providers & associates only
Consent	Explicit, informed, and freely given	Based on treatment/payment operations
Penalties	€20M or 4% of global revenue	\$100 to \$1.5M per violation

Data Rights	Access, correct, delete, restrict, transfer	Access and correction of PHI only
Breach Notification	Within 72 hours	Within 60 days

 **EXAM TIP:** GDPR = broad (ALL personal data, ALL organizations globally). HIPAA = narrow (ONLY health data, ONLY US healthcare). GDPR fines are much higher.

9. Intellectual Property Rights (IPR)

IPR are legal protections for 'creations of the mind' — inventions, creative works, brand identifiers, and trade secrets. They incentivize innovation and protect creators.

📌 Asked in: 2024 Q1 (trade secrets), 2025 Q1 – IPR, 2025 Q5 – Software Piracy

5 Core Types of Intellectual Property

- **Patents (Inventions)** – Exclusive rights for new, novel, non-obvious, and useful inventions (products or processes). Protection: 20 years. Example: a new drug formula or manufacturing process.
- **Copyrights (Original Works)** – Protects expressions of ideas — literary, dramatic, musical, artistic works, software, films. In India: author's lifetime + 60 years. Example: a book, song, or software code.
- **Trademarks (Brand Identity)** – Signs, logos, names, or symbols that distinguish goods/services of one entity from another. Renewable indefinitely every 10 years. Example: the Nike swoosh, Apple logo.
- **Trade Secrets (Confidential Information)** – Formulae, methods, practices, or designs that provide competitive advantage and are kept secret. No formal registration — protection depends on secrecy. Example: Coca-Cola formula.
- **Geographical Indications (GI)** – Identifies goods originating from a specific region with unique qualities or reputation linked to that origin. Example: Darjeeling Tea, Alphonso Mango, Kolhapuri Chappal.

Software Piracy

Software piracy is the unauthorized reproduction, distribution, or use of copyrighted software.

- **Types: –**
 - **End-user piracy** – Installing software on more systems than the license allows
 - **Counterfeiting** – Producing and selling fake copies of software
 - **Internet piracy** – Downloading software from unauthorized websites
 - **Hard disk loading** – Pre-installing pirated software on computers for sale
- **Consequences: –**
 - **Legal** – Criminal penalties under Copyright Act and IT Act
 - **Financial** – Fines and civil suits for damages
 - **Security** – Pirated software often contains malware

📌 **EXAM TIP:** Trade secrets have NO time limit and NO registration — protection exists as long as secrecy is maintained. Piracy = violation of COPYRIGHT (not patent or trademark).

10. Quick Revision — All Topics at a Glance

Topic	Key Points to Remember	Exam Frequency
Incident Response Life Cycle	6 phases: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned	★★★★★
CERT	8 roles: Detection, Response, Threat Intel, Vulnerability Mgmt, Coordination, Forensics, Training, Policy	★★★★☆
Digital Forensics Techniques	7 techniques: Disk Imaging, File Carving, Memory Forensics, Live Acquisition, Network, Email, Steganography	★★★★☆
Evidence Collection	4 steps: Collection → Examination → Analysis → Reporting (Media→Data→Info→Evidence)	★★★★☆
Chain of Custody	Chronological record; 4 components: Documentation, Unique ID, Hashing, Storage; Analysis on COPY only	★★★★★
IT Act 2000	Section 66 (hacking=3yr), 66E (privacy=3yr), 66F (terrorism=LIFE), 67 (obscene=5yr)	★★★★★
DPDP Act 2023	India's data privacy law; Data Principal (user) + Data Fiduciary (org); penalty up to ₹250 crore	★★★☆☆
GDPR vs HIPAA	GDPR=all personal data, worldwide, €20M fine; HIPAA=health data only, US only, \$1.5M/violation	★★★★☆
IPR	5 types: Patent (20yr), Copyright (life+60yr), Trademark (forever), Trade Secret (no limit), GI	★★★★☆
Software Piracy	Unauthorized use/copying of copyrighted software; violates Copyright Act & IT Act	★★★☆☆

All the best for your ESE! 🎓

Study smart, revise often, and trust your preparation.